DATA CLASSIFICATION POLICY

POL-001 | Issued under the Information Management Framework

Document ID: POL-001
Version: 1.0 — DRAFT
Parent Framework: IMF-001 Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Data Classification Policy
Document ID	POL-001
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Chief Information Officer
Custodian	Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	ISO/IEC 27001:2022, GDPR, HIPAA, CCPA, GxP, SOX

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes mandatory requirements for the classification of all data assets owned, processed, stored, or transmitted by [Company Name]. It operationalises the Data Sensitivity axis of the classification schema defined in the Information Management Framework (IMF-001).

Data classification is the foundation of [Company Name]'s information risk management approach. Without it, controls cannot be proportionate to risk, regulatory obligations cannot be met, and accountability cannot be assigned. This Policy ensures that every data asset is labelled, handled, and protected in a manner commensurate with its sensitivity.

2. Scope

This Policy applies to:

- All data created, collected, received, stored, processed, or transmitted by [Company Name] or on its behalf
- All employees, contractors, consultants, and third parties who handle [Company Name] data
- All environments in which company data resides: on-premises, cloud, hybrid, and endpoint devices
- All data formats: structured databases, unstructured files, emails, physical documents, and verbal communications where recorded

This Policy must be read in conjunction with POL-005 (System Classification Policy), POL-003 (Data Integrity Policy), and POL-004 (Privacy Policy).

3. Policy Statement

All data assets at [Company Name] must be classified according to the sensitivity tiers defined in this Policy. Classification must be:

- Assigned at the point of creation or receipt
- Visible on the asset (via labelling, metadata, or document headers) wherever technically feasible
- Reviewed and reconfirmed at least annually by the designated Data Owner
- Escalated to a higher tier whenever the nature of the data changes

Where data of different sensitivity tiers is combined — for example, a report containing both Public and Sensitive Personal information — the entire asset must be classified at the highest tier present.

4. Data Sensitivity Classification Tiers

All [Company Name] data must be assigned to one of the following five tiers. Tiers are ordered from least to most sensitive.

Tier 1 — Public

Attribute	Detail
Definition	Information that has been formally approved for unrestricted external distribution.
Disclosure Risk	None. Disclosure is intentional and expected.
Regulatory Sensitivity	None.
Examples	Press releases, published annual reports, approved marketing materials, public website content, job postings.
Labelling Requirement	No label required on external-facing material. Internal documents classified Public must carry the label PUBLIC.
Handling	No restrictions on storage, transmission, or sharing. Standard IT security hygiene applies.

Tier 2 — Business Use

Attribute	Detail
Definition	General internal information intended for use within the company. Not approved for public disclosure but carrying no special regulatory obligation.
Disclosure Risk	Low. Unauthorised disclosure is unlikely to cause material harm.
Regulatory Sensitivity	None specific. General duty of confidentiality applies.
Examples	Internal memos, project plans, standard operating procedures, internal training materials, meeting minutes (non-executive), IT support tickets.
Labelling Requirement	All documents must carry the label INTERNAL — BUSINESS USE.
Handling	May be shared freely within the organisation. External sharing requires manager approval. Must not be posted publicly without authorisation. Encrypted in transit for external sharing.

Tier 3 — Sensitive

Attribute	Detail
Definition	Information whose unauthorised disclosure could cause reputational, financial, competitive, or operational harm to [Company Name].
Disclosure Risk	Medium to High.
Regulatory Sensitivity	May attract regulatory scrutiny if disclosed (e.g., material non-public information under securities law).
Examples	Business strategies, financial forecasts, commercial contracts, M&A target lists, pricing models, audit findings, board-level communications.
Labelling Requirement	All documents must carry the label SENSITIVE — CONFIDENTIAL.
Handling	Access on a need-to-know basis only. External sharing requires Director-level approval and NDA in place. Encrypted at rest and in transit. Must not be stored on personal devices or unapproved cloud services.

Tier 4 — Sensitive Personal

Attribute	Detail
Definition	Personal data relating to identified or identifiable individuals, as defined under applicable privacy legislation (GDPR, HIPAA, CCPA). Subject to heightened regulatory obligation.
Disclosure Risk	High. Breach triggers regulatory notification obligations and significant reputational damage.
Regulatory Sensitivity	GDPR, HIPAA, CCPA, and all other applicable privacy regulations. Mandatory breach notification applies.
Examples	Employee HR records, payroll data, patient data, clinical trial subject data, customer PII (names, addresses, contact details), genetic or biometric data, health records.
Labelling Requirement	All documents must carry the label SENSITIVE PERSONAL — RESTRICTED. Systems must be flagged accordingly in the Asset Register.
Handling	Access strictly limited to authorised personnel with documented business need. Data minimisation principles apply. Pseudonymisation or anonymisation where feasible. Encrypted at rest and in transit using approved encryption standards. Cross-border transfer subject to Data Transfer Impact Assessment. Retention strictly governed by POL-002.

Tier 5 — Highly Confidential

Attribute	Detail
Definition	The highest sensitivity tier. Information whose unauthorised disclosure could cause severe and potentially irreversible harm to [Company Name] or others.
Disclosure Risk	Critical. Disclosure may constitute a criminal offence, regulatory breach, or catastrophic business loss.
Regulatory Sensitivity	May engage securities law, regulatory submission obligations, GxP data integrity requirements, or criminal statutes.
Examples	Trade secrets, unpublished regulatory submissions (IND, NDA, BLA), cryptographic keys and credentials, M&A transaction details, Board deliberation on material events, whistleblower identity data.
Labelling Requirement	All documents must carry the label HIGHLY CONFIDENTIAL — RESTRICTED. Systems must be flagged in the Asset Register with enhanced monitoring enabled.
Handling	Access limited to named individuals on a documented need-to-know basis, approved by the Data Owner and CISO. Multi-factor authentication mandatory. End-to-end encryption required. Physical documents stored in locked, access-controlled environments. Printing restricted; printed copies tracked. Destruction via certified secure shredding only.

5. Data Handling Requirements Summary

The following matrix summarises the minimum handling controls required per sensitivity tier. Subordinate Work Instructions provide step-by-step guidance for each control.

Control	Public	Business Use	Sensitive	Sensitive Personal	Highly Confidential
Document Labelling	Optional	Required	Required	Required	Required
Access Control	None	Standard IAM	Need-to-know	Named individuals + approval	Named individuals + CISO approval + MFA
Encryption at Rest	Not required	Recommended	Required	Required	Required (approved algorithms only)
Encryption in Transit	Not required	Required (external)	Required	Required	Required end-to-end
External Sharing	Unrestricted	Manager approval	Director approval + NDA	DPO + legal approval	CISO + General Counsel approval
Cloud Storage	Approved services	Approved services	Approved services only	Approved & audited services only	Prohibited without CISO sign-off
Printing	Unrestricted	Standard	Restricted	Restricted + tracking	Restricted + tracking + secure collection
Retention / Disposal	Per POL-002	Per POL-002	Per POL-002 + legal hold awareness	Per POL-002 + privacy regulation	Per POL-002 + certified destruction only
Breach Notification	Not applicable	IT team	CISO within 24 hrs	CISO + DPO within 1 hr	CISO + DPO + General Counsel within 1 hr

6. Roles and Responsibilities

Role	Responsibility
Data Owner	Business leader accountable for a defined data domain. Assigns and periodically reconfirms the classification of all data within their domain. Approves access requests above standard thresholds.
Data Custodian (IT)	IT or system function responsible for implementing the technical controls mandated by the classification assigned by the Data Owner.
Information Security	Provides classification guidance, adjudicates disputes, maintains the classification standard, and monitors compliance.
Data Protection Officer (DPO)	Advises on classification of personal data (Tier 4) and ensures compliance with privacy regulation requirements.
All Personnel	Responsible for correctly labelling data they create, handling data in accordance with its classification, and reporting suspected misclassification or breaches.

7. Classification Process

Data classification must follow the process defined in SOP-001 (Data Classification Process). In summary:

Step	Action	Responsible
1	Identify — determine what data asset is being created or received, and what it contains.	Creator / Recipient
2	Assess — evaluate the nature of the data against the tier definitions in Section 4. Where data spans multiple tiers, apply the highest.	Data Owner
3	Assign — record the classification in the document header, file metadata, or system record as applicable.	Creator / Data Owner
4	Apply Controls — implement the handling controls required for the assigned tier per Section 5.	Data Custodian (IT) / Creator
5	Register — log the asset in the Corporate Asset Register with its classification and owner.	Data Custodian (IT)
6	Review — reconfirm classification at least annually or when the nature of the data changes.	Data Owner

8. Reclassification and Declassification

Data may be reclassified upward at any time by the Data Owner without additional approval. Reclassification downward (to a less sensitive tier) requires:

- Written justification from the Data Owner
- Approval from Information Security
- For Tier 4 data: additional approval from the DPO
- For Tier 5 data: additional approval from the CISO

Declassification decisions and approvals must be recorded in the Corporate Asset Register with a timestamp and rationale.

9. Third Party Obligations

Third parties who receive or process [Company Name] data are required to handle that data in accordance with its classification, as specified in:

- The applicable Data Processing Agreement (DPA) or contract
- The Third Party and Vendor Risk Policy (POL-013)

Third parties must not reclassify company data or apply lesser controls than those specified. Compliance with classification requirements is subject to audit under POL-013.

10. Non-Compliance

Failure to comply with this Policy may result in:

- Disciplinary action up to and including termination of employment or contract
- Regulatory penalties and fines where a breach of applicable law has occurred
- Civil or criminal liability depending on the nature of the breach

Suspected non-compliance must be reported to Information Security immediately. All reports will be investigated in accordance with the Incident Response Policy (POL-012).

11. Policy Exceptions

Exceptions to this Policy may only be granted by the CISO in writing. All exceptions must:

- Document the specific requirement being excepted and the business justification
- Define compensating controls that mitigate the associated risk

- Specify an expiry date (maximum 12 months)
- Be recorded in the Information Risk Register

No exception may be granted that would cause [Company Name] to breach applicable law or regulatory obligation.

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework — defines classification schema
POL-005	System Classification Policy	Governs system criticality classification
POL-002	Data Retention and Disposal Policy	Governs retention periods per classification tier
POL-003	Data Integrity Policy	Governs data accuracy and ALCOA+ requirements
POL-004	Privacy Policy	Governs Tier 4 Sensitive Personal data
POL-008	Access Control Policy	Governs IAM controls derived from classification
POL-013	Third Party and Vendor Risk Policy	Governs third-party data handling obligations
SOP-001	Data Classification Process	Operationalises this Policy
EXC-001	Exception Management Policy and Register	All data classification exceptions — including reclassification to a lower tier — are governed by EXC-001; classification tier exceptions affect downstream control obligations across the IMF suite
WI-001	Data Classification Questionnaire	Step-by-step classification tool

13. Definitions

Term	Definition
Data Asset	Any collection of data, in any format, that has value to [Company Name].
Data Owner	The business leader accountable for a defined data domain, including its classification and appropriate use.

Term	Definition
Data Custodian (IT)	The IT or system function responsible for implementing technical controls on behalf of the Data Owner.
Personal Data	Any information relating to an identified or identifiable natural person, as defined under applicable privacy law.
Pseudonymisation	Processing of personal data such that it can no longer be attributed to a specific individual without the use of additional, separately held information.
Sensitivity	The confidentiality risk associated with the unauthorised disclosure of a data asset.
Need-to-Know	The principle that access to information is granted only to individuals who require it to perform a defined, legitimate business function.

— End of Document —

POL-001 v1.0 DRAFT | [Company Name] | CONFIDENTIAL